

CipherScan

Real-Time Mobile Threat Interception, Headless Cloud Sandboxing & Fintech Fraud Prevention

*This report presents the complete engineering architecture of **CipherScan** — a cross-platform Mobile Threat Defense framework that intercepts web and payment URLs at the Android OS intent layer before browser execution, routes each link through a remote headless Chromium sandbox, evaluates 70+ antivirus reputation feeds, and applies specialized heuristics for Indian banking and UPI payment fraud. Evaluated against a benchmark of **5,000 real-world URIs**, CipherScan achieves **98.42 % detection accuracy** with an F1-score of 0.984 and zero continuous battery overhead.*

Index Terms — Android Security, Malicious URL Detection, Cloud Sandboxing, Quishing, Smishing, UPI Payment Fraud, Playwright Headless Browser, Threat Intelligence, SSRF.

DOCUMENT TYPE

Master Engineering & Architecture Report

CORE THREAT ENGINE

Playwright Chromium · VirusTotal v3 · Google Safe Browsing v4

PLATFORM STACK

Android (Kotlin) · Node.js · React · Neon PostgreSQL

EVALUATION SCOPE

5,000 URLs · 70+ AV Engines · Indian UPI Deep-Link Analysis

V1.0 PRODUCTION

1. Executive Summary

CipherScan reverses the link-opening sequence: every URI is fully analyzed in a cloud sandbox before the local browser is permitted to load even a single byte of the destination page.

A native Android application intercepts every tapped URL across SMS, WhatsApp, Telegram, and camera-based QR scanners, forwarding each URI to a cloud threat engine that combines Playwright headless browser detonation, VirusTotal v3 / Google Safe Browsing v4 reputation aggregation, Shannon entropy heuristics, and a specialized Indian fintech fraud module. A Material 3 overlay card presents the verdict with supporting evidence before any navigation proceeds. A React-based web command centre aggregates telemetry across all connected devices via a zero-trust Vercel BFF proxy that keeps API credentials server-side.

98.42%

DETECTION ACCURACY

0.984

F1-SCORE

<180ms

CACHED RESPONSE

0%

CONTINUOUS BATT. DRAIN

70+

AV ENGINE FEEDS

2. Problem Statement

Over 75 % of malicious links are encountered on mobile platforms. The structural design of mobile OSes amplifies exposure in ways desktop environments do not face, and all existing mitigations carry significant trade-offs.

2.1 Platform Vulnerabilities

- **Truncated address bars** hide deceptive subdomains (e.g., `sbi.co.in.kyc-alert.xyz`).
- **No hover previews** — touchscreens enforce immediate execution on tap with no destination preview.
- **UPI deep-link execution** — `upi://pay` invokes payment apps directly, bypassing all browser security.
- **Zero-day domains** — attackers rotate disposable domains every few hours, outpacing 4–24 h blacklist propagation.

2.2 Failure of Existing Solutions

- **VPN interceptors** inflict 10–15 % daily battery overhead and raise BYOD privacy objections.
- **Browser extensions** cannot intercept links inside native apps — SMS clients and camera scanners operate outside the browser process.
- **Lexical classifiers** (Random Forest, XGBoost, LightGBM) fail on JS redirect chains and shortened URLs; high false-negative rates on zero-day domains.
- **Western AV platforms** have no coverage of Indian UPI manipulation or VPA impersonation.

3. Related Work & Literature Gaps

Recent literature has explored ML-based URL classification using lexical and host-based features [1, 5, 6]. The *QsecR* framework (2023) [4] evaluates 39 features in an Android QR scanner, and 2025 IEEE IWCMC studies [7] demonstrated attackers leveraging URL shorteners and Browser-in-the-Browser (BiTB) overlays to defeat client-side scanners. However, three critical gaps remain in all reviewed frameworks: (i) inability to trace complex dynamic multi-hop redirections without a live browser; (ii) complete absence of emerging-market fintech threat analysis for UPI deep-links; and (iii) lack of real-time administrative telemetry for enterprise security teams. CipherScan is designed explicitly to close all three gaps.

Scope note. CipherScan targets Android (API 26+). iOS parity via Safari Content Blocker is a Phase 4 item. Limitations: requires cloud connectivity (airplane mode unsupported); proprietary schemes `whatsapp://` and `tg://` are not scanned; Cloudflare Turnstile pages receive partial scans (reputation scores complete; screenshot shows challenge screen). A pre-built debug APK is available at `cipherscan-debug.apk`.

4. System Architecture & Data Flow

CipherScan is organized into four decoupled tiers with well-defined API contract boundaries. All inter-tier communication is secured with HTTPS and bearer API key authentication. The Android client handles OS-level interception and presentation. The cloud engine owns sandboxing, reputation aggregation, and persistence. The database provides the immutable audit store. The web layer exposes telemetry through a zero-trust BFF proxy.

CIPHERSCAN — FOUR-TIER ARCHITECTURE	
TIER 1 ANDROID CLIENT <i>android/ · Kotlin · Material 3</i>	▶ LinkInterceptorActivity.kt — Transparent, windowless gatekeeper. Captures <code>ACTION_VIEW</code> for <code>http</code>, <code>https</code>, <code>upi</code>; holds navigation until verdict is returned from cloud engine. ▶ SecurityOverlayBottomSheet.kt — Material 3 bottom sheet: color-coded risk gauge (green 0–20 / amber 21–69 / red 70–100), Coil Base64 preview, redirect chain log, Abort / Proceed controls. ▶ MainActivity.kt — Home screen: live status card, manual URL/UPI scanner, direct web dashboard launcher, and quick test triggers for demo purposes. ▶ BrowserLauncher.kt · RetrofitClient.kt — Explicit Chrome CCT dispatch via <code>FLAG_ACTIVITY_NEW_DOCUMENT</code>; OkHttp singleton with 60 s timeouts and auto <code>x-api-key</code> injection. <code>POST /api/analyze {targetUrl, triggerType, deviceId, x-api-key}</code> ▾ <code>Response: {verdict, riskScore, screenshot, redirectChain, reasons}</code> ▲
TIER 2 THREAT ENGINE <i>api-server/ · Node.js · Render</i>	▶ urlSafety.ts — SSRF guard: resolves DNS pre-flight; rejects RFC 1918, loopback <code>127.0.0.0/8</code>, and EC2 metadata <code>169.254.169.254</code>. Permits only <code>http</code>, <code>https</code>, <code>upi</code>. ▶ sandboxService.ts — Headless Playwright Chromium: traces HTTP 301/302/307 and JS <code>window.location</code> chains; captures 1280×720 JPEG as Base64 Data URI. 24-hour cache for repeat URLs. ▶ reputationService.ts · indianFraudEngine.ts — Parallel VirusTotal v3 + GSB v4 queries; Levenshtein distance brand matching; UPI <code>pa</code> / <code>pn</code> / <code>am</code> / <code>tn</code> parameter dissection for reverse-payment scams. <code>INSERT INTO scans</code> ▾ <code>SELECT * FROM scans ORDER BY createdAt DESC</code> ▲
TIER 3 DATABASE <i>lib/db/ · Drizzle ORM · Neon</i>	▶ scans table — Permanent audit log: original URL, final URL, verdict, risk score, redirect chain JSON, Base64 screenshot, device UUID, device model, and timestamp. ▶ Neon Serverless Postgres — Auto-scales to zero between scans; ideal for bursty mobile scan workloads without idle billing. <code>GET /api/scans</code> <code>GET /api/stats</code> <code>GET /api/stats/timeline</code> ▲ (via Vercel BFF — server-side <code>x-api-key</code> injection)
TIER 4 WEB DASHBOARD <i>cipherscan/ · React · Vercel</i>	▶ api/proxy.js — Vercel Serverless Function: injects <code>x-api-key</code> from server-side env variable before forwarding to Render. React bundle contains zero credentials. ▶ Dashboard.tsx · Analyze.tsx · ScanHistory.tsx · ScanDetail.tsx — 7-day timeline, threat taxonomy, manual URL/UPI analyzer, paginated scan log, per-scan detail with lightbox screenshot zoom.

4.1 Shared Type Contracts & API Hooks (`lib/api-zod/` , `lib/api-client-react/`)

Zod runtime validation schemas (`lib/api-zod/`) enforce strict input/output contracts on all API requests. TanStack React Query hooks (`lib/api-client-react/`), auto-generated via Orval from the OpenAPI 3.1 spec (`lib/api-spec/openapi.yaml`), provide fully typed frontend data access.

API Hooks Reference

Hook	Endpoint
<code>useAnalyzeUrl</code>	<code>POST /api/analyze</code>
<code>useListScans</code>	<code>GET /api/scans</code>
<code>useGetDashboardStats</code>	<code>GET /api/stats</code>
<code>useGetScanTimeline</code>	<code>GET /api/stats/timeline</code>

4.2 Transaction Sequence

User taps link → `LinkInterceptorActivity` catches intent → `POST /api/analyze` dispatched via Retrofit → SSRF guard validates synchronously → parallel coroutines for sandbox + reputation → unified risk score computed → audit record inserted into Postgres → JSON response returned → Material 3 overlay renders verdict. Total latency: <180 ms (cached) · 1.8–3.2 s (cold sandbox detonation).

5. Threat Scoring Formulation

The engine computes a *Unified Risk Score* $R(u) \in [0, 100]$ for any input URI u — a weighted linear combination of five independent threat signals, hard-capped at 100 to prevent compound amplification between correlated sources:

$$R(u) = \min\{100, w_{vt} \cdot S_{vt} + w_{gsb} \cdot S_{gsb} + w_{red} \cdot S_{red} + w_{heu} \cdot S_{heu} + w_{upi} \cdot S_{upi}\}$$

Eq. 1 — Unified Risk Score · $\sum w_i = 1.0$ · Safe ≤ 20 · Suspicious 21–69 · Malicious ≥ 70

Table 1 — Component weights and normalization

Component	w_i	Signal & Normalization
S_{vt} — VirusTotal	0.40	$S_{vt} = \min(100, \text{hits}/5 \times 100)$ across 70+ AV vendors. Strongest empirical predictor of known malicious infrastructure.
S_{gsb} — Safe Browsing	0.30	Binary: 100 if Google Safe Browsing v4 returns any threat match (MALWARE, SOCIAL_ENGINEERING, UNWANTED_SOFTWARE); 0 otherwise.
S_{red} — Redirect chain	0.10	$S_{red} = \min(100, (N_{\text{hops}} - 1) \times 30 + \text{domainSwitches} \times 25)$. Multi-domain redirect chains are a strong cloaking indicator.
S_{heu} — Heuristics	0.10	Suspicious TLD (.xyz, .top, .tk) +20; Shannon $H(D) > 4.25$ +25; excessive URL depth and numeric subdomains add further penalties.
S_{upi} — Fintech	0.10	UPI parameter analysis: reverse-payment indicators, VPA impersonation, zero-amount mandate traps, and merchant name anomalies.

5.1 Shannon Domain Entropy

DGA and randomised phishing subdomains exhibit high character-level entropy. For domain D of length L :

$$H(D) = -\sum P(x_i) \log_2 P(x_i)$$

Eq. 2 · $H(D) > 4.25 \rightarrow +25$ penalty on S_{heu}

Empirical calibration across 5,000 test URIs established $H(D) = 4.25$ as the optimal detection threshold.

5.2 SSRF Guard (Formal)

Let $IP(u)$ represent resolved IPv4/IPv6 addresses. Connection is aborted immediately if:

$$IP(u) \in \{ 10.0.0.0/8 \cup 172.16.0.0/12 \\ \cup 192.168.0.0/16 \cup 127.0.0.0/8 \\ \cup 169.254.169.254/32 \}$$

Eq. 3 — SSRF protected address space

Only `http`, `https`, and `upi` protocol schemes pass validation; all others are rejected before Playwright is invoked.

6. Android Mobile Client (`android/`)

The application registers as the system-default handler for `http`, `https`, and `upi` URI schemes via `AndroidManifest.xml` intent filters with `autoVerify="true"`. A `<queries>` block satisfies Android 11+ package visibility requirements for explicit browser targeting.

Table 2 — Android source files and key design decisions

File	Role & Key Design Decision
<code>LinkInterceptorActivity.kt</code>	Windowless, transparent activity. Captures <code>intent.dataString</code> , shows non-blocking spinner overlay, dispatches <code>analyzeURL()</code> via Kotlin Coroutines on IO dispatcher with exponential-backoff retry.
<code>MainActivity.kt</code>	Home screen with live ecosystem status card, manual URL/UIP text input analyzer, direct Web Dashboard launcher button, and one-tap demo scan triggers for evaluation purposes.
<code>SecurityOverlayBottomSheet.kt</code>	Material 3 <code>BottomSheetDialogFragment</code> : color-coded risk gauge, Coil-loaded Base64 JPEG, expandable redirect chain, threat bullet reasons, and Abort / Proceed action buttons.

7. Cloud Threat Engine (`artifacts/api-server/`)

7.1 Playwright Sandbox (`sandboxService.ts`)

Upon clearing SSRF validation, the engine launches an isolated headless Chromium context. The sandbox intercepts all HTTP `response` events to build an ordered redirect chain, follows 301/302/307 hops and client-side `window.location` assignments, and records the terminal landing URL. A 1280×720 JPEG is captured and encoded as a self-contained `data:image/jpeg;base64,...` Data URI — immune to broken external links across all deployment environments. A 24-hour database-backed cache collapses repeat safe-URL invocations to sub-180 ms lookups.

7.2 Indian Fraud Engine (`indianFraudEngine.ts`)

Computes Levenshtein edit distance against official domains for SBI, HDFC, ICICI, Axis, PNB, Kotak, IRCTC, and India Post — flagging typosquatting near-misses. Detects free-tier hosting abuse (`*.firebaseapp.com`, `*.vercel.app`, `*.pages.dev`) when URLs contain banking keywords. For `upi://pay`, fully parses `pa`/`pn`/`am`/`tn` — identifying reverse-payment scams where the note promises a refund while `am` encodes a positive debit.

8. Database Schema (`lib/db/src/schema/scans.ts`)

Listing 1 — Drizzle ORM scans table

```
export const scansTable = pgTable("scans", {
  id: serial("id").primaryKey(),
  originalUrl: text("original_url").notNull(), // URI tapped
  finalUrl: text("final_url"), // After redirects
  verdict: text("verdict").notNull(), // safe|suspicious|malicious
  riskScore: integer("risk_score").notNull(), // [0, 100]
  redirectChain: jsonb("redirect_chain"), // [{url, statusCode}]
  previewImageUrl: text("preview_image_url"), // Base64 Data URI
  triggerType: text("trigger_type").notNull(), // link|camera|manual
  virusTotalScore: integer("virustotal_score"), // Flagging engine count
  googleSafeBrowsing: boolean("google_safebrowsing"), // GSB flag
  deviceId: text("device_id"), // Encrypted UUID
  deviceName: text("device_name"), // e.g. Samsung SM-G991B
  createdAt: timestamp("created_at").defaultNow(),
});
```

Env Variables

Table 4 — Required environ

Variable
<code>DATABASE_URL</code>
<code>SESSION_SECRET</code>
<code>VIRUSTOTAL_API_KEY</code>
<code>GOOGLE_SAFE_BROWSI</code>
<code>APP_API_KEY</code>

Deployment targets:

Frontend: Vercel (Re
Serverless Postgres.
Store internal track.

7.3 API Route Reference

Table 3 — Backend routes (`src/routes/`)

Route	Method	Purpose
<code>/api/analyze</code>	POST	Core scan orchestrator
<code>/api/scans</code>	GET	Paginated scan log w/ verdict filter
<code>/api/scans/:id</code>	GET	Single scan detail
<code>/api/stats</code>	GET	Aggregate dashboard metrics
<code>/api/stats/timeline</code>	GET	7-day scan volume series
<code>/api/stats/threats</code>	GET	Threat taxonomy breakdown
<code>/api/healthz</code>	GET	Service health probe

9. Hypothetical Attack Edge Cases

Case 1 — Zero-Day Domain

An attacker registers a fresh `.xyz` domain 10 minutes before sending an SMS.

Case 2 — IP-Cloaking Attack

The attacker's server checks the visitor's User-

Case 3 — Spoofed UPI VPA

SMS reads: "Pay electricity bill to avoid disconnection" with `upi://pay?pa=fakeluzbill@paytm&pn=ElectricityBoard&am=50000`.

10. Operational Coverage & Benchmark Evaluation

Table 5 — Coverage matrix across attack vectors

Attack Vector	Coverage
SMS phishing (smishing)	Full
WhatsApp / Telegram links	Full
Physical QR codes (quishing)	Full
UPI payment QR codes	Full
Shortened URLs (bit.ly, t.co)	Full
Manual paste in app	Full
Social in-app WebViews	Not auto
Google Lens QR tap	Conditional
Cloudflare Turnstile pages	Partial scan
Offline / Airplane mode	Unsupported
Custom schemes (whatsapp://)	Not scanned
Private LAN / SSRF probing	Blocked

Table 6 — Classification results (5,000 URI benchmark)

Metric	Value
Overall accuracy	98.42 %
True positives (TP)	2,467 / 2,500
False negatives (FN)	33 (Recall: 98.68 %)
False positives (FP)	46 (Specificity: 98.16 %)
Precision	98.17 %
F1-Score	0.984

Table 7 — Latency breakdown

Phase	Time
SSRF + heuristics	8 ms
GSB + VirusTotal (parallel)	420 ms
Playwright sandbox	1,840 ms
Cached response	<180 ms
Full cold scan	1.8–3.2 s

11. Viva Defence · Roadmap · Conclusion

Key Examiner Q&A

Q1. Why OS-level interception, not a browser extension?

Extensions only exist inside a browser process. Over 75 % of mobile phishing is tapped in SMS, WhatsApp, and camera apps that expose no extension API. Intent interception is the only architecture covering all three surfaces without changing user behavior.

Q2. How are intent loops prevented?

`BrowserLauncher.kt` targets `com.android.chrome` with `FLAG_ACTIVITY_NEW_DOCUMENT`, creating an independent Chrome task. The interceptor's intent filter never matches URLs launched from an existing Chrome document task.

Q3. How are API credentials protected on the web dashboard?

The Vercel serverless proxy injects `x-api-key` from a server-side env variable inaccessible to client-side JavaScript, DevTools, or bundle analysis tools.

Q4. What makes UPI detection unique vs

Bitdefender/Norton? Global AV vendors focus exclusively on Western binary malware (PE files, Windows exploits). They carry no coverage of Indian fintech threat vectors — UPI deep-link tampering, VPA handle impersonation, reverse-payment scams, or `upi://pay` parameter

Roadmap

- **Phase 2 — Visual AI.** CLIP / YOLOv8 logo impersonation detection on zero-day domains that pass reputation checks but clone a bank's visual identity.
- **Phase 3 — Enterprise MDM.** Remote policy management, per-app allowlists, SIEM syslog export for Splunk / Elastic.
- **Phase 4 — iOS Parity.** Safari Content Blocker + Share Extension + SwiftUI threat overlay.

Conclusion. CipherScan demonstrates that effective mobile threat defense does not require continuous network interception. By shifting the security boundary to the OS intent layer and delegating analysis to a cloud sandbox, the system protects users across all link-entry surfaces with zero idle battery overhead.

References

- [1] S. Althunibat et al., *Frontiers in Computer Science*, vol. 6, 2024.
- [2] M. A. Al-Shareeda & S. Manickam, *IEEE Networking Letters*, vol. 7, no. 1, 2025.
- [4] Y. Zhang et al., *IEEE Access*, vol. 11, pp. 78210–78224, 2023.